Relazione finale S9L5

Analisi della cattura di rete `Cattura_U3_W1_L5.pcapng`

📌 Obiettivo dell'esercizio

Analizzare una cattura di rete fornita (`.pcapng`) per:

1. Identificare eventuali **IOC (Indicatori di Compromissione)**
2. Formulare ipotesi sui **vettori di attacco**
3. Suggerire **azioni di mitigazione** per ridurre l'impatto dell'attacco

🖥️ 1. Preparazione dell'ambiente

🔧 Importazione del file su Kali Linux

Per spostare il file dalla cartella condivisa al Desktop:

```
cd /media/sf_cartella_condivisa
mv "Cattura_U3_W1_L5.pcapng" /home/kali/Desktop
chmod ugo+rw /home/kali/Desktop/Cattura_U3_W1_L5.pcapng
chown kali:kali /home/kali/Desktop/Cattura_U3_W1_L5.pcapng
```

🦈 Apertura della cattura con Wireshark

ho fatto doppio click al file dal Desktop, in alternativa si poteva aprire dal bash

🔍 2. Analisi del traffico – Filtri e osservazioni

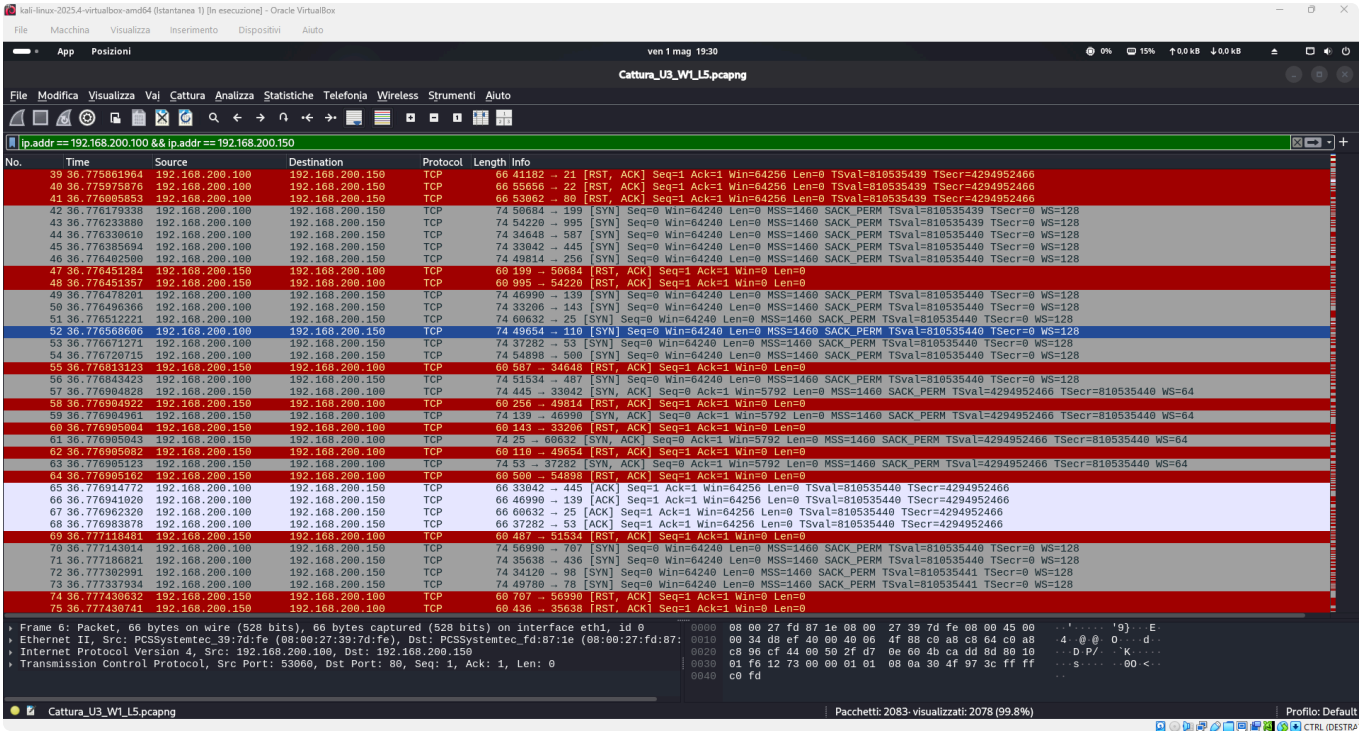
🎯 Filtro applicato

Per isolare il traffico tra i due host coinvolti:

su wireshark

```
ip.addr == 192.168.200.100 && ip.addr == 192.168.200.150
```

> Questo filtro mostra esclusivamente le comunicazioni tra l'host sospetto (100) e la vittima (150).



🚨 3. IOC Identificati (Indicatori di Compromissione)

⚠️ IOC #1 – Massiccio Port Scanning

Dalla vista filtrata emergono:

- Numerosi pacchetti **TCP SYN** inviati da 192.168.200.100
- Porte di destinazione **sempre diverse** (21, 22, 23, 80, 111, 443, 445, 554, 993, 995, ecc.)
- Risposte della vittima:
  - **SYN/ACK** → porta aperta
  - **RST/ACK** → porta chiusa

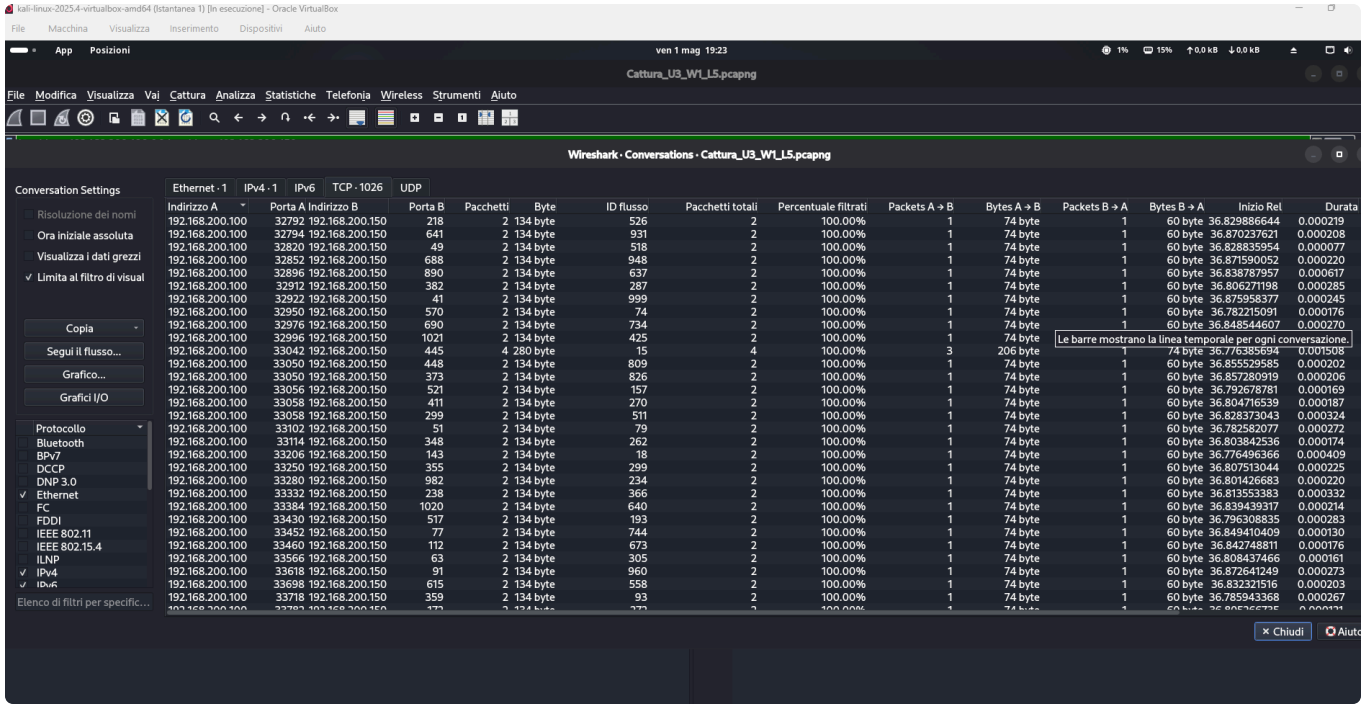
👉 Questo pattern è tipico di un **SYN Scan** (Nmap -sS).

⚠️ IOC #2 – Connessioni con durata nulla

Da **Statistiche** → **Conversazioni** → **TCP**:

- Ogni connessione ha **durata ≈ 0.0002s**

- Ogni flusso contiene **solo 1–2 pacchetti**
- Le porte cambiano rapidamente



👉 Questo conferma un comportamento di **ricognizione attiva**.

🎯 4. Ipotesi sul vettore di attacco

Dai dati raccolti, il comportamento dell'host 192.168.200.100 indica:

🔎 Fase di ricognizione (Scanning)

L'attaccante sta:

- Enumerando le porte aperte
- Identificando i servizi attivi
- Preparando un possibile exploit successivo

🧨 Possibili obiettivi dell'attaccante

In base alle porte sondate:

- **SSH (22)** → brute force
- **FTP (21)** → credenziali deboli

- **Telnet (23)** → accesso non cifrato
- **SMB (445)** → exploit EternalBlue / Samba
- **HTTP/HTTPS (80/443)** → vulnerabilità web
- **RPC (111/135)** → enumerazione servizi Windows/Linux

🛡️ 5. Azioni di mitigazione

🚨 Azione immediata

- Bloccare l'IP 192.168.200.100 tramite firewall:

bash

```
sudo iptables -A INPUT -s 192.168.200.100 -j DROP
```

- Abilitare rate limiting:

bash

```
sudo iptables -A INPUT -p tcp --syn -m limit --limit 1/s -j ACCEPT
```

🔐 Azione preventiva

- Segmentare la rete (la macchina vulnerabile non deve stare sulla LAN)
- Disabilitare servizi non necessari (Telnet, FTP, SMBv1)
- Aggiornare e patchare i servizi esposti
- Installare IDS/IPS (Snort, Suricata, Zeek)
- Applicare firewall host-based (UFW, iptables)
- Monitorare i log di sistema (SSH, auth.log, syslog)

📚 6. Conclusione

L'analisi della cattura mostra chiaramente un **attacco di ricognizione** tramite **SYN Port Scan.** Il comportamento è tipico della fase iniziale di un attacco informatico, finalizzato a identificare servizi vulnerabili da sfruttare successivamente.

Le misure di mitigazione proposte permettono di:

- bloccare l’attacco in corso
- ridurre la superficie d’attacco
- prevenire futuri tentativi simili